Open-Source Software and Code Usage Policy

Policy ID: POL-ENG-001 | Version 1.0 | Classification: Internal

Policy Owner	Chief Technology Officer / CISO	**Effective Date**	12 September 2026
Review Cycle	At least annually and upon material legal, threat, technology, or business change	**Approval Authority**	Executive Risk / Information Security Governance Committee
Applies To	Enterprise workforce, controlled entities, and in-scope suppliers	**Control Status**	Mandatory unless formally excepted

Mandatory language: "MUST" and "MUST NOT" indicate mandatory requirements. "SHOULD" indicates an expected control that may be varied only when a risk-based alternative is documented. "Strictly Prohibited" identifies conduct that is not permitted absent an explicit, legally valid emergency or exception pathway.

1. Objective

This policy establishes mandatory governance, security, licensing, provenance, and maintenance requirements for the acquisition, use, modification, contribution, distribution, and embedding of open-source software (OSS). The objective is to obtain the engineering benefits of OSS without introducing unacceptable legal, supply-chain, confidentiality, privacy, or cybersecurity risk. OSS is treated as third-party software and may not bypass normal security architecture, procurement, or release controls.

2. Scope

This policy applies to employees, contractors, interns, suppliers, and any other person who writes, builds, packages, deploys, or distributes software on behalf of the enterprise. It covers source code, binaries, packages, container images, model weights, firmware components, snippets copied from public repositories, transitive dependencies, build plugins, command-line tools, and OSS used in internal systems, customer products, demonstrations, prototypes, or production services.

3. Governance, Accountability, and Roles

Engineering teams. Maintain dependency inventories, select approved components, remediate vulnerabilities, and comply with license obligations.

Application Security. Defines scanning gates, reviews high-risk dependencies, and blocks components with unacceptable vulnerability or provenance risk.

Legal / IP Counsel. Approves copyleft, source-disclosure, patent, attribution, and redistribution obligations.

Procurement / Third-Party Risk. Performs due diligence for commercially supported OSS and critical maintainers or vendors.

Developers. May introduce OSS only through approved package-management and repository processes; they remain accountable for dependencies they add.

4. Policy Rules and Mandatory Guidelines

- All OSS introduced into a codebase MUST have an identifiable upstream project, version, license, source location, and accountable internal owner. Unversioned downloads and binaries of unknown provenance are Strictly Prohibited.
- Every production repository MUST generate and retain a software bill of materials (SBOM) at build or release time. The SBOM MUST include direct and transitive dependencies and SHOULD use SPDX or CycloneDX formats.
- Only dependencies obtained from approved artifact repositories or verified upstream registries MAY be used. Direct downloads from personal file-sharing services, paste sites, messaging applications, or untrusted mirrors are Strictly Prohibited.

- Copyleft or reciprocal licenses that can impose source-disclosure or distribution obligations, including strong-copyleft licenses, MUST receive written Legal approval before use in a distributed product, embedded appliance, SDK, client application, or customer-delivered container.
- Developers MUST NOT remove copyright notices, license files, attribution notices, NOTICE files, or authorship information required by an applicable license.
- Abandoned, archived, or unmaintained projects MUST NOT be introduced into Tier-1 or Internet-facing production systems unless a documented risk acceptance names an internal maintenance strategy or supported fork.
- Dependencies with known active exploitation, a critical severity vulnerability, or evidence of malicious maintainer compromise MUST be quarantined or removed on an emergency basis. Product teams MUST follow vulnerability remediation SLAs defined by the vulnerability-management program.
- Typosquatting indicators, suspicious package ownership changes, install-time scripts that retrieve remote payloads, encoded or obfuscated post-install behavior, and unexpected credential/network access MUST trigger security review before installation.
- OSS used only for development is not automatically exempt. Build tools, CI plugins, test frameworks, linters, and code generators can execute with sensitive credentials and MUST meet the same provenance and scanning requirements when they run in privileged environments.
- Contribution of enterprise-developed code to an external OSS project MUST follow the approved contribution process. Confidential source, proprietary algorithms, customer information, security findings, credentials, internal hostnames, or unpublished roadmap information MUST NOT be contributed.
- Forking an OSS project creates an internal maintenance obligation. Fork owners MUST define update monitoring, merge cadence, security patching, and end-of-life criteria.
- Package-lock, poetry.lock, uv.lock, go.sum, Cargo.lock, or equivalent lockfiles MUST be committed for reproducible builds where the ecosystem supports them. Floating dependency ranges in production builds are prohibited unless technically unavoidable and formally approved.

5. Technical and Coding Constraints

- Source repositories MUST enable automated software composition analysis (SCA). Approved examples include SonarQube/SonarCloud dependency analysis, Snyk, Mend, GitHub Advanced Security, GitLab dependency scanning, or an enterprise-equivalent control. A project MUST NOT rely only on manual review.
- CI/CD pipelines MUST fail on dependencies that match the enterprise denylist, contain malware indicators, lack a determinable license, or exceed the approved vulnerability threshold. Exception approvals MUST be machine-linkable to the build or release record.
- Release artifacts MUST be built from pinned sources. Container base images MUST reference immutable digests for production releases; mutable tags such as latest are not sufficient release controls.
- Dependency integrity SHOULD be verified using ecosystem mechanisms such as checksums, signed releases, Sigstore/cosign, npm integrity metadata, Maven checksums/signatures, or equivalent. For critical components, maintainers and release-signing provenance MUST be assessed.
- Production applications MUST NOT dynamically execute code downloaded from public repositories at runtime. Runtime package installation from the public Internet is Strictly Prohibited for production workloads except for an approved update mechanism with integrity and rollback controls.
- Build agents MUST use least-privilege credentials. Package install scripts MUST NOT have access to production secrets. Where possible, build jobs MUST run in isolated ephemeral environments with outbound egress limited to approved registries.
- Secrets scanners MUST run before merge and release. API keys, tokens, private keys, customer data, or credentials discovered in a public fork MUST be treated as an incident and rotated immediately; deletion from Git history alone is not considered containment.

- License and SCA scans MUST be performed on every release candidate and on a scheduled basis for maintained products so that new upstream vulnerabilities are detected after deployment.

6. Operational Control Requirements

- The enterprise MUST maintain an approved-source registry and an OSS exception register. Product owners MUST review high-risk dependency exceptions at least quarterly.
- Critical OSS components MUST have an identified replacement, supported fork, vendor support option, or documented contingency where loss of upstream maintenance would materially affect service availability or security.
- Security advisories from upstream projects, national vulnerability databases, vendor feeds, and internal intelligence MUST be correlated with the SBOM to identify affected assets.

7. Monitoring, Assurance, and Records

Compliance with this policy MUST be demonstrable. Evidence is part of the control, not an optional administrative artifact. Records MUST be retained according to the enterprise records-retention schedule, legal holds, applicable regulation, and contractual requirements.

Minimum expected records:

- SBOMs and release manifests
- SCA and license scan results
- OSS exception approvals
- Attribution/NOTICE artifacts
- Security remediation tickets
- External contribution approvals

Security, Internal Audit, Privacy, Legal, Compliance, and authorized risk functions MAY request evidence and perform sampling or technical validation. System owners MUST provide accurate evidence and MUST NOT suppress, alter, or fabricate control records.

8. Enforcement and Violation Consequences

Violation may result in rejected pull requests, blocked releases, package quarantine, revocation of repository or CI privileges, mandatory remediation, disciplinary action up to and including termination, contractual remedies for suppliers, and legal escalation where licensing or IP obligations are breached. Security may require immediate removal of a component without waiting for a normal release window when active exploitation or malicious supply-chain activity is suspected.

Where a violation creates active risk, protective action may occur before disciplinary or contractual review is complete. Enforcement decisions will consider intent, recurrence, severity, impact, legal duties, and whether the individual promptly reported the issue and cooperated with remediation.

9. Exceptions and Risk Acceptance

Exceptions MUST identify the component, version, license, business justification, compensating controls, vulnerability status, distribution model, legal assessment where relevant, accountable owner, and expiration date. Open-ended exceptions are prohibited. Critical-risk exceptions require CISO approval; material license exceptions require Legal approval.

An exception MUST NOT be interpreted as permanent policy change. The control owner may require additional monitoring, narrower scope, remediation milestones, or earlier review. Expired exceptions automatically cease to authorize the deviation.

10. Standards and Regulatory Alignment

This policy is designed to support the enterprise ISMS and cybersecurity risk program. Mappings are implementation aids; they do not replace a formal applicability analysis, legal advice, or the authoritative standards and regulations.

Framework	Policy alignment
ISO/IEC 27001:2022	Supports supplier/security-in-development, vulnerability, configuration, change, and secure coding control objectives within the ISMS.
NIST CSF 2.0	GV.SC supply-chain governance; ID.AM asset/dependency awareness; PR.PS platform/software security; DE.CM continuous monitoring; RS.MI mitigation.
GDPR	Articles 5(1)(f), 25 and 32 apply where OSS components process personal data; processor/subprocessor obligations must also be considered where hosted services are involved.

Authoritative reference set

- ISO/IEC 27001:2022, Information security, cybersecurity and privacy protection - Information security management systems - Requirements. This policy supports the ISMS risk-management model and applicable Annex A controls without reproducing proprietary standard text.
- NIST Cybersecurity Framework (CSF) 2.0, NIST CSWP 29 (2024). Control outcomes are organized across GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, and RECOVER as applicable.
- Regulation (EU) 2016/679 (General Data Protection Regulation, GDPR), including the principles of Article 5 and, where applicable, Articles 6, 25, 28, 30, 32, 33, 34, 35, and Chapter V on international transfers.

11. Review, Maintenance, and Approval

The policy owner MUST review this document at least annually and whenever a material incident, audit finding, law/regulation, technology change, threat development, merger/acquisition, or operating-model change may affect its adequacy. Proposed changes MUST be version-controlled and approved through the enterprise policy governance process. Local procedures may impose stricter requirements but MUST NOT weaken this policy without an approved exception.

End of controlled document.